

Network security

Les 3b

Network security

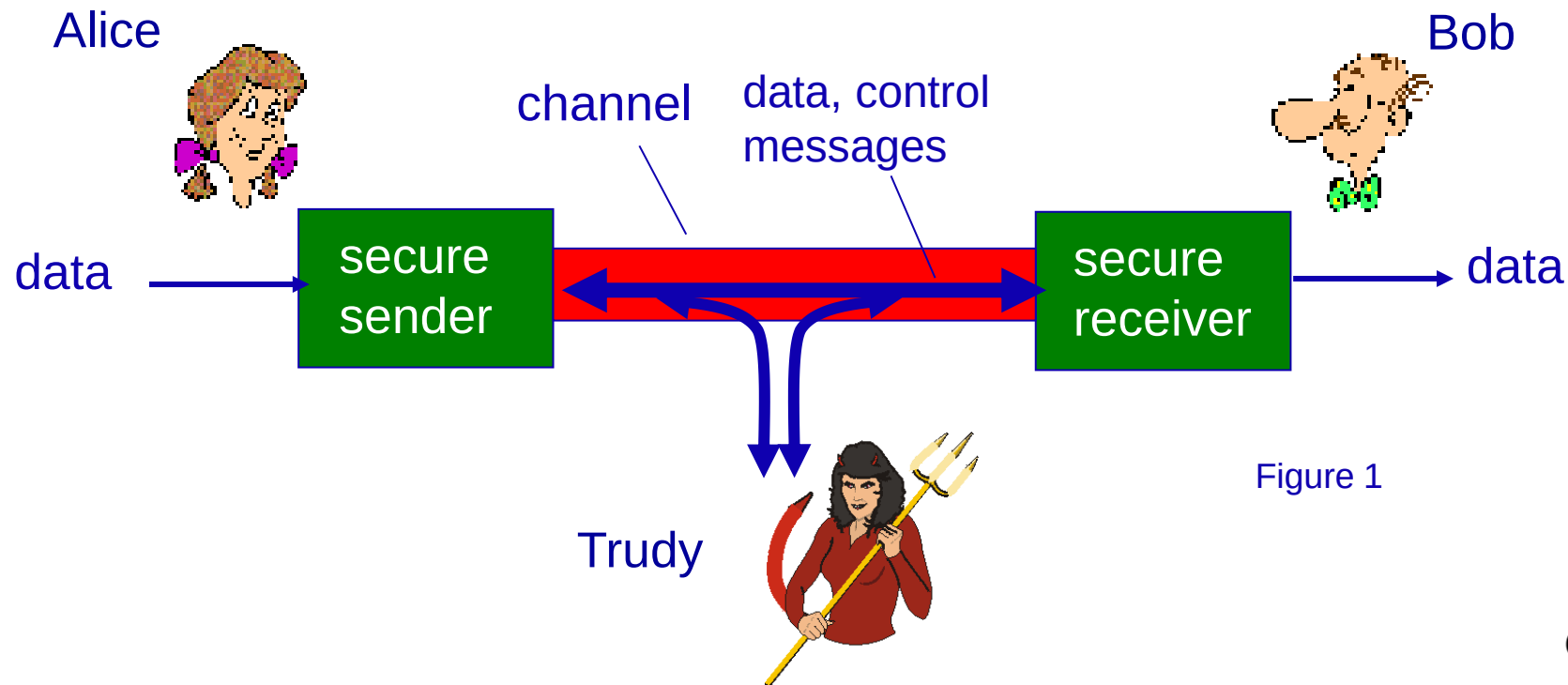
- Reminder: security threats
- Aspects of network security:
 - Confidentiality
 - Message integrity
 - Authentication
 - Operational Security
- Security policy
- Cryptography: Symmetric and Public / Private Key
- Message authentication and digital signatures
- SSL
- VPN
- Firewall and Intrusion Detection Systems (IDS)
- DMZ

Security threats: recap

- Internet not originally designed with (much) security in mind
 - *original vision*: “a group of mutually trusting users attached to a transparent network” 😊
 - Internet protocol designers playing “catch-up”
 - security considerations in all layers!
- Possible threats
 - Malware: virus, worm, spyware, ransomware
 - DDOS attacks
 - Spam
 - Sniff packets
 - Fake packets
 - ...

Friends and enemies: Alice, Bob, Trudy

- Well-known in network security world
- Bob, Alice (lovers!) want to communicate “securely”
- Trudy (intruder) may intercept, delete, add messages



There are bad guys (and girls) out there!

Q: What can a “bad guy” do?

A: A lot! See section 1.6

- *eavesdrop*: intercept messages
- actively *insert* messages into connection
- *impersonation*: can fake (spoof) source address in packet (or any field in packet)
- *hijacking*: “take over” ongoing connection by removing sender or receiver, inserting himself in place
- *denial of service*: prevent service from being used by others (e.g., by overloading resources)

Bad guys: attack server, network infrastructure

- *Denial of Service (DoS)*: attackers make resources (server, bandwidth) unavailable to legitimate traffic by overwhelming resource with bogus traffic

1. select target
2. break into hosts around the network (see botnet)
3. send packets to target from compromised hosts

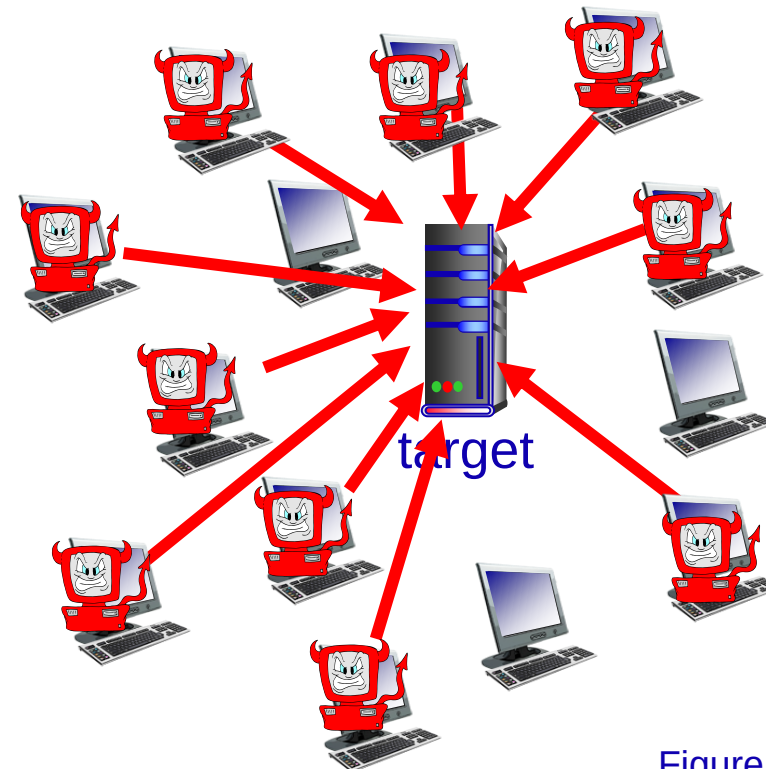


Figure 16 Creating Tomorrow

What is network security?

- *Confidentiality*: only sender, intended receiver should “understand” message contents
 - sender encrypts message
 - receiver decrypts message
- *Message integrity*: sender & receiver want to ensure message not altered (in transit, or afterwards) without detection
- *Authentication*: sender & receiver want to confirm identity of each other
- *Operational security*: keep out the bad guys by using firewalls and intrusion detection, thus making sure that services remain available to legitimate users.



[Link to movie](#)

Figure 2

Creating Tomorrow

Security policy

- Organisational policy outlining a vision (not technical details)
- Signed by management
- Management shows the importance of security (commitment)
- And assigns a security officer to handle day to day business

Compliance

Comply with laws, rules and regulations

- Code Tabaksblat - NL
- Wet Melding Datalekken - NL
- GDPR (General Data Protection Regulation)
- AVG (Algemene verordening gegevensbescherming)
- Sarbanes-Oxley ("SOX") - US
- Payment Card Industry Data Security Standard (PCI DSS)

Risk analysis (RA)

Determine:

- Potential risks
- Chances of risk occurring
- Expected damage
- Possible mitigation:
 - Technical solutions: firewall, antivirus, etc
 - Hand-over of the risk: insure or outsource
 - Accept that things may go wrong...
 - Or combinations of the above

Risk analysis (RA)

Example, a **website**:

- website may be **hacked**
- **chances**: once every 5 years
- **damage**: € 80.000
- therefore: **risk** is € 16.000 / year
- **solution**: firewall, costs € 10.000 / year

Technical protection

- Firewall
- Routers, modems, etc. with a packet filter
- Antivirus
- IDS : Intruder Detection System
- IPS : Intruder Prevention System
- IDP : Identity Provider
- Data protection (bijvoorbeeld BitLocker)
- Data encryption
- Security awareness



Defense in Depth Layers

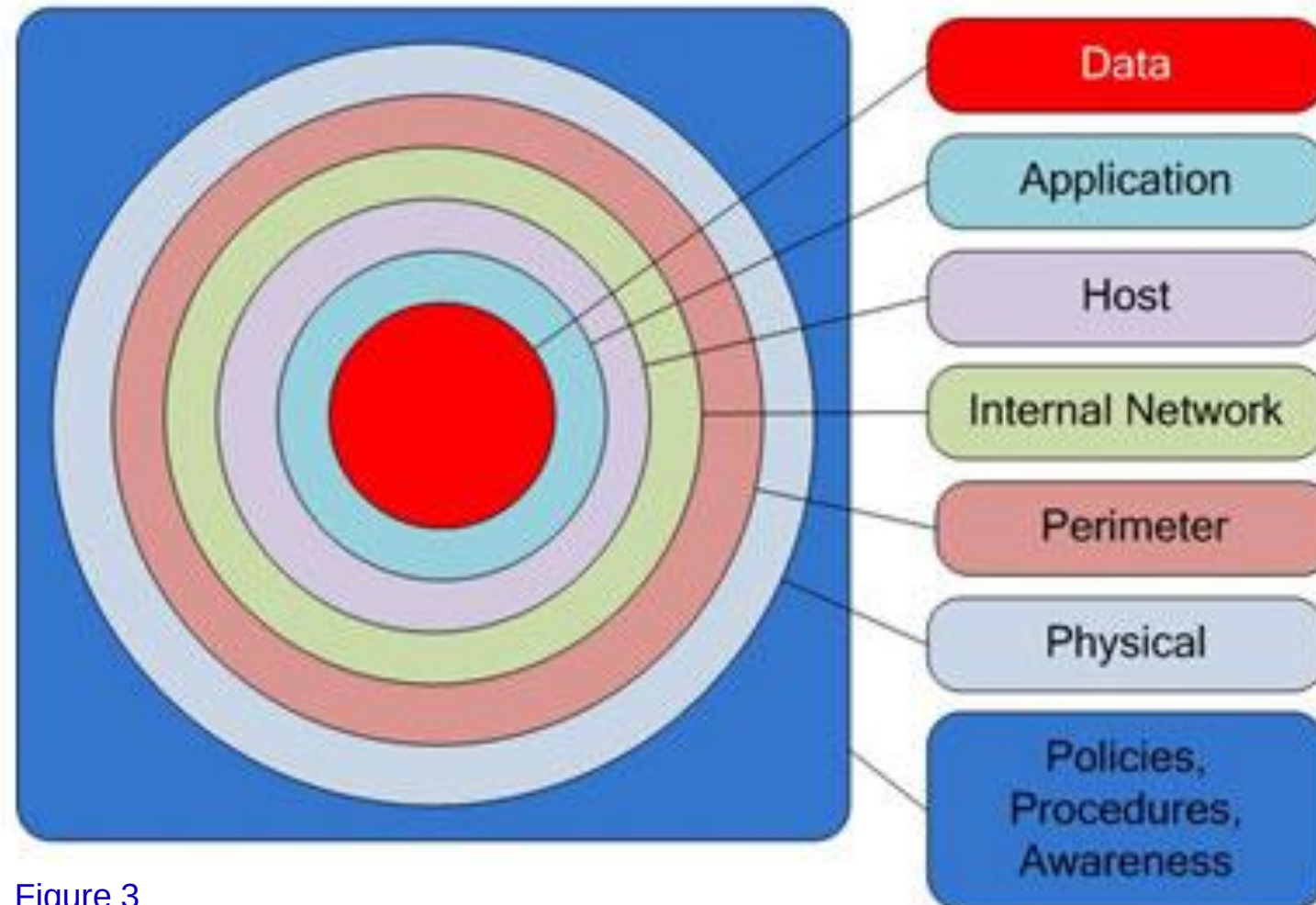
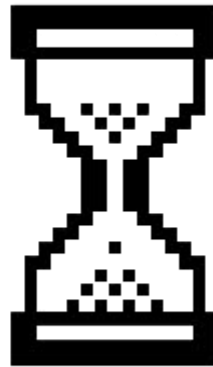


Figure 3



Break



Symmetric key cryptography

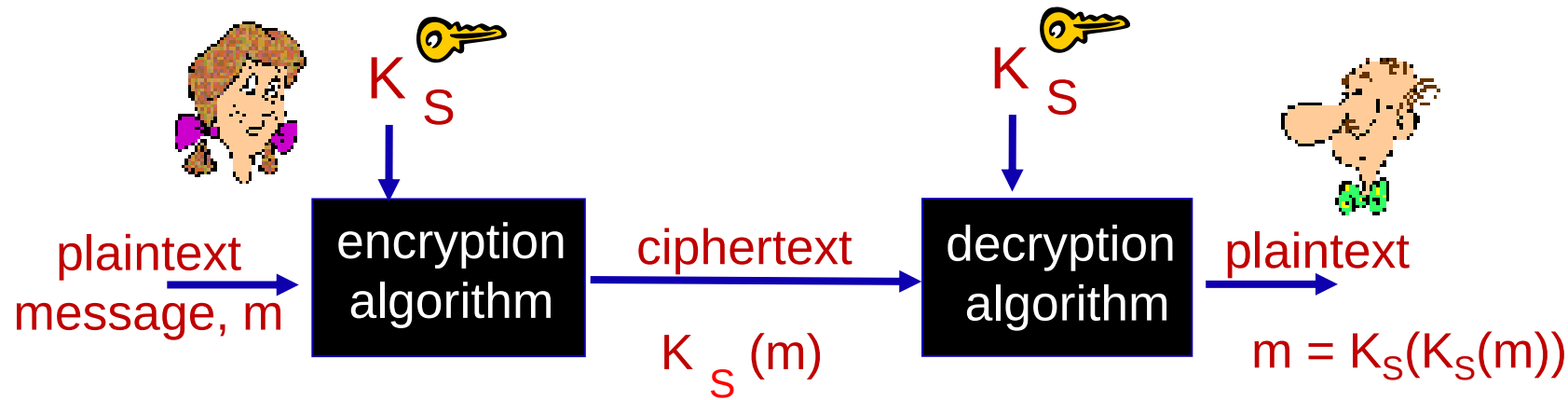


Figure 4

symmetric key crypto: Bob and Alice share same (symmetric) key: K

- e.g., key is knowing substitution pattern in mono alphabetic substitution cipher

Q: how do Bob and Alice agree on key value?

Simple encryption scheme

substitution cipher: substituting one thing for another

- monoalphabetic cipher: substitute one letter for another

plaintext:	abcdefghijklmnopqrstuvwxyz
	↓ ↓
ciphertext:	mnbvcxzasdfghjklpoiuytrewq

e.g.: Plaintext: bob. i love you. alice
ciphertext: nkn. s gktc wky. mgsbc

 *Encryption key*: mapping from set of 26 letters
to set of 26 letters

Public Key Cryptography

symmetric key crypto

- requires sender, receiver know shared secret key
- Q: how to agree on key in first place (particularly if never “met”)?

public key crypto

- ❖ radically different approach [Diffie-Hellman76, RSA78]
- ❖ sender, receiver do *not* share secret key
- ❖ *public* key known to *all*
- ❖ *private* key known only to receiver

Public Key Cryptography

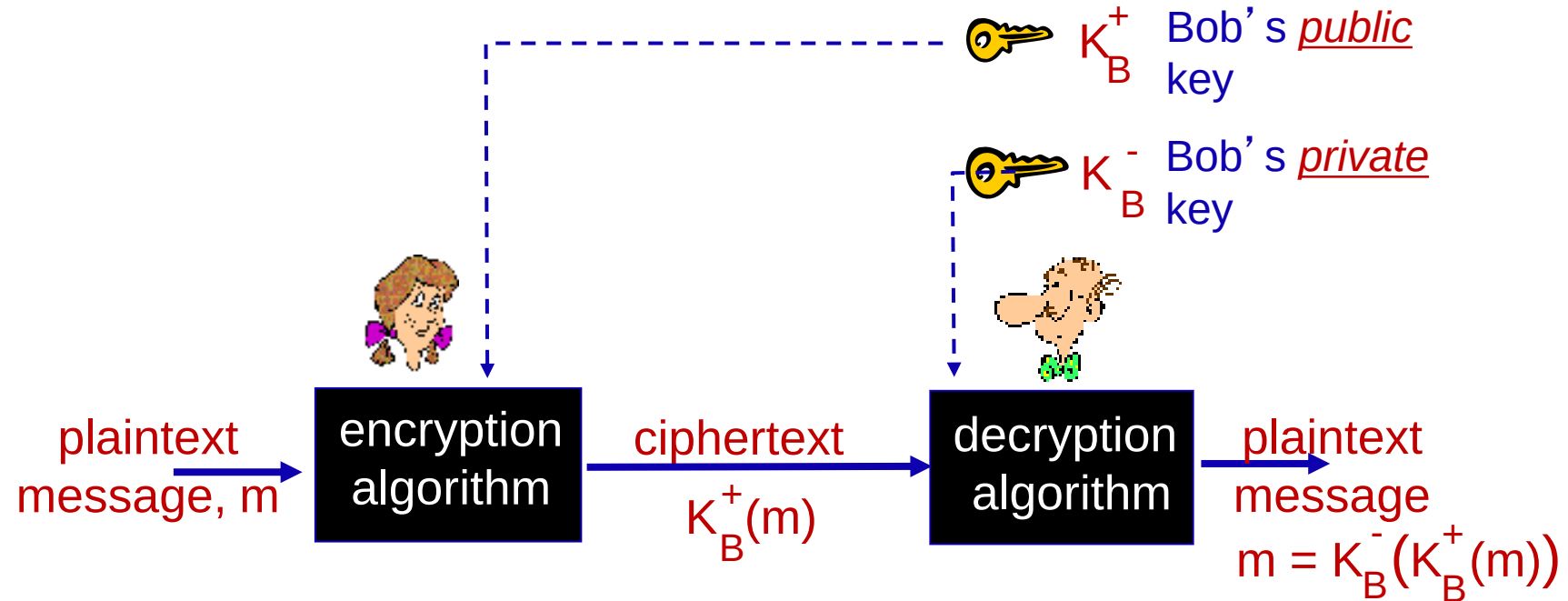


Figure 5

Digital signatures

simple digital signature for message m :

- Bob signs m by encrypting with his private key K_B , creating “signed” message, $K_B(m)$

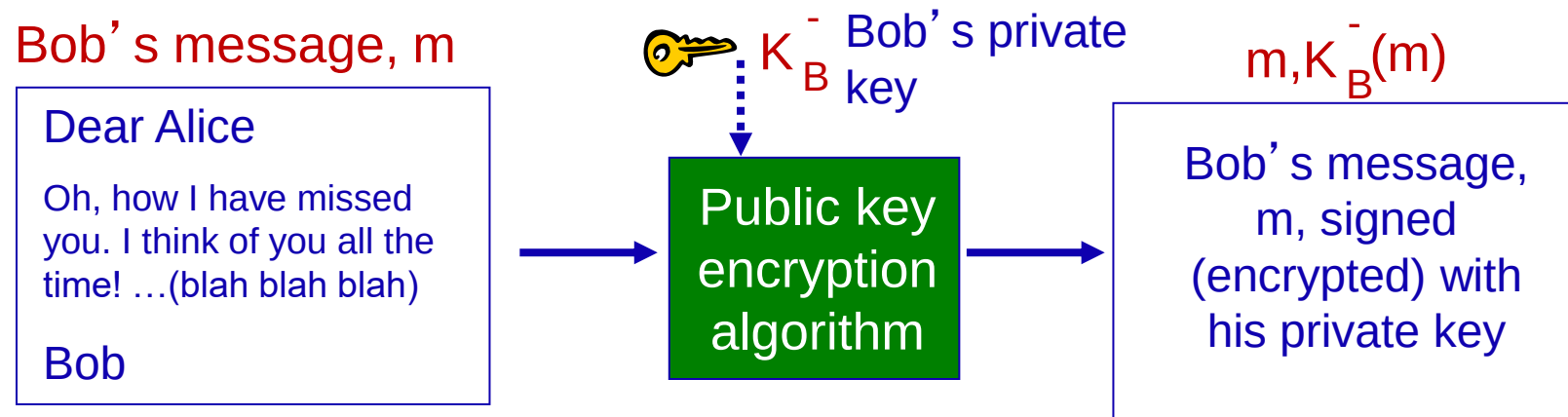
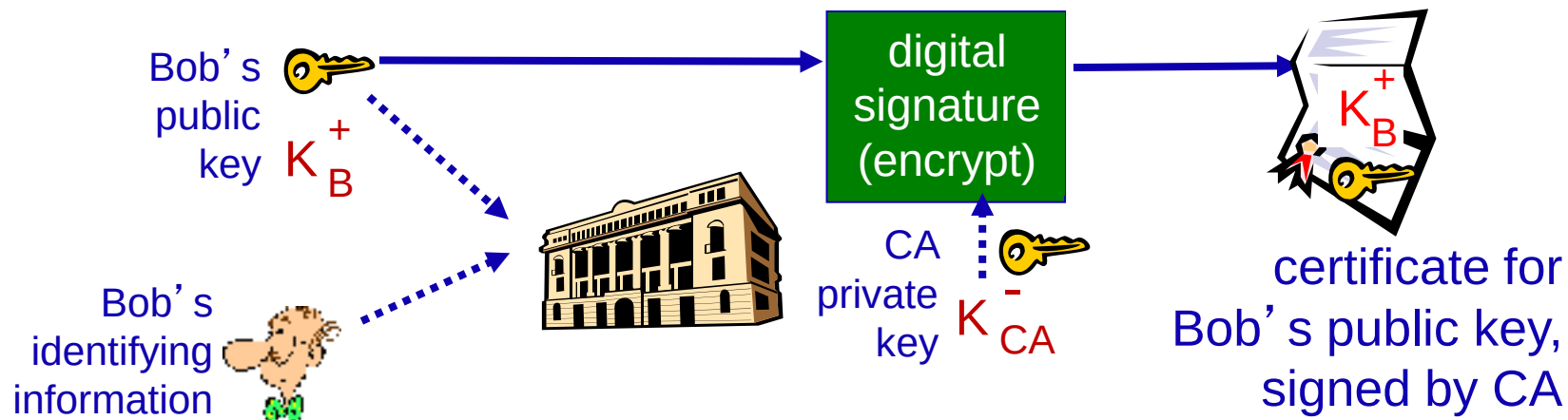


Figure 6

Certificate authorities

- *certificate authority (CA)*: binds public key to particular entity, E.
- E (person, router) registers its public key with CA.
 - E provides “proof of identity” to CA.
 - CA creates certificate binding E to its public key.
 - certificate containing E’s public key digitally signed by CA – CA says “this is E’s public key”



Message digests

computationally expensive to public-key-encrypt long messages

goal: fixed-length, easy- to-compute digital “fingerprint”

- apply hash function H to m , get fixed size message digest, $H(m)$.

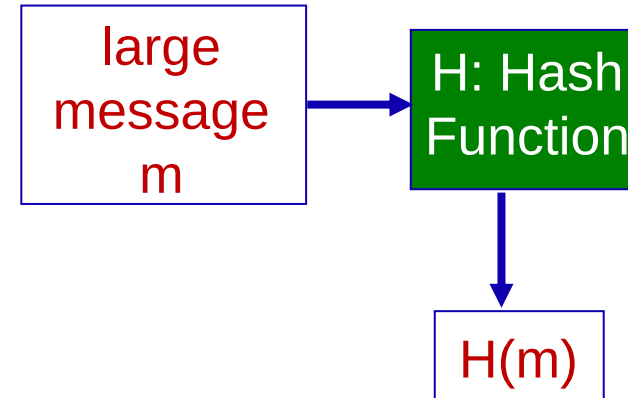
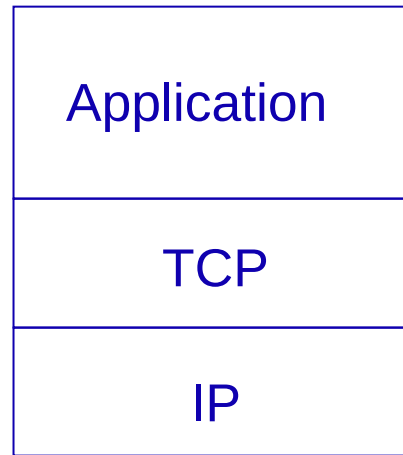


Figure 8

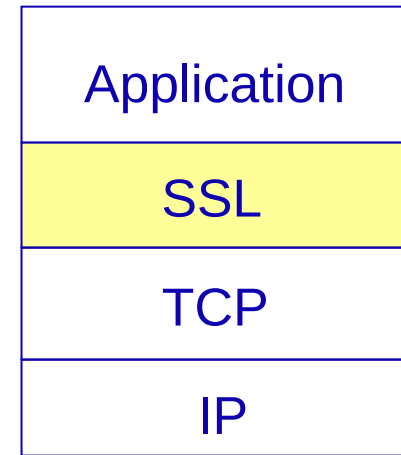
Hash function properties:

- many-to-1
- produces fixed-size msg digest (fingerprint)
- given message digest x , computationally infeasible to find m such that $x = H(m)$

SSL and TCP/IP



normal application



application with SSL

Figure 9

- ❖ SSL provides application programming interface (API) to applications
- ❖ C and Java SSL libraries/classes readily available

Virtual Private Networks (VPNs)

motivation:

- institutions often want private networks for security.
 - costly: separate routers, links, DNS infrastructure.
- VPN: institution's inter-office traffic is sent over public Internet instead
 - encrypted before entering public Internet
 - logically separate from other traffic

offers network layer confidentiality:

- all data sent from one entity to other would be hidden:
web pages, e-mail, P2P file transfers, TCP SYN packets ...
- “blanket coverage”

uses IPSEC protocols for security:

- data integrity, origin authentication, replay attack prevention,
- confidentiality

Virtual Private Networks (VPNs)

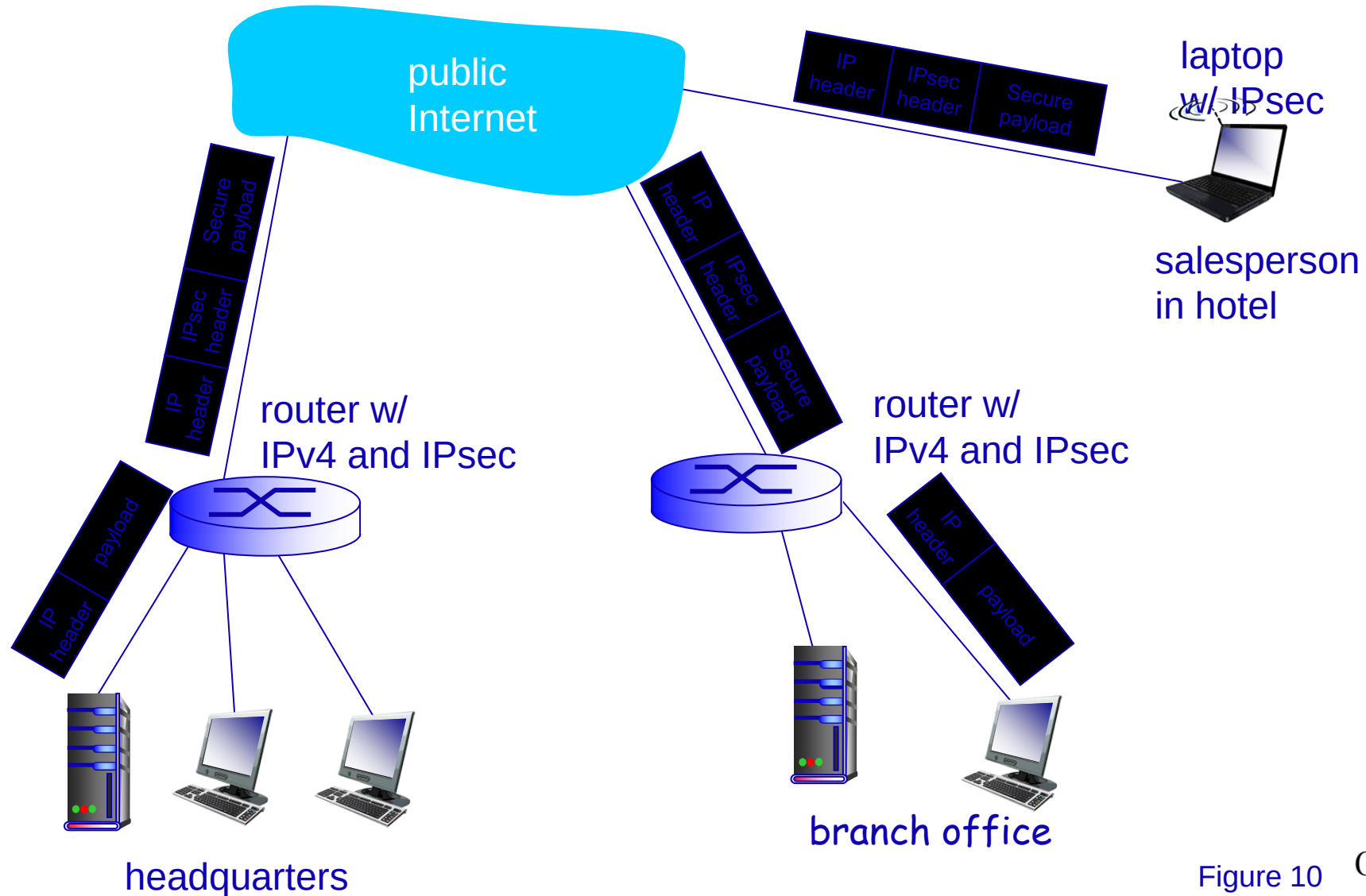


Figure 10 Creating Tomorrow

Firewalls

firewall

isolates organization's internal net from larger Internet, allowing some packets to pass, blocking others

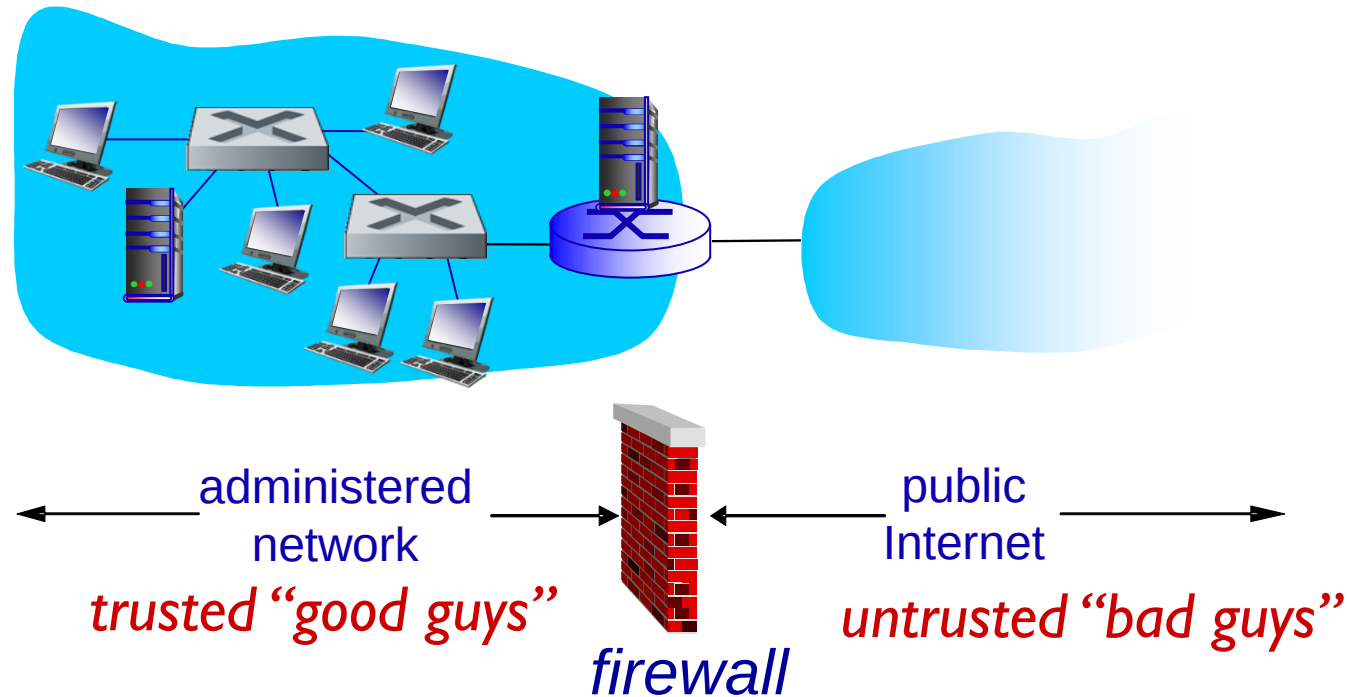


Figure 11 Creating Tomorrow

Packet filtering

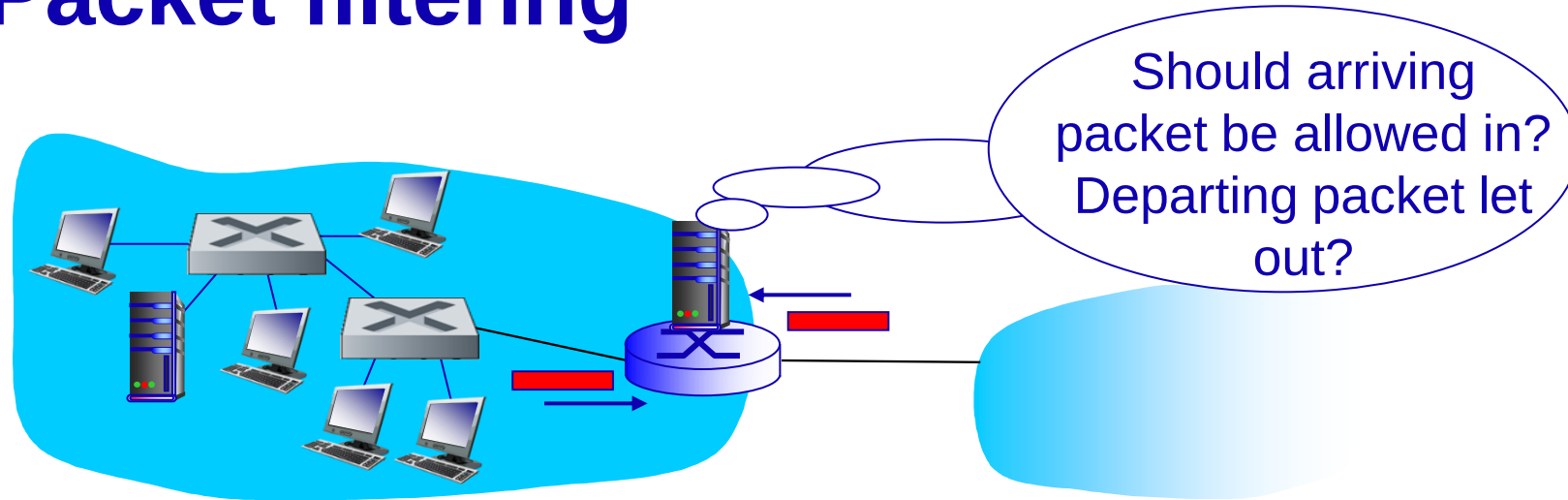


Figure 12

- internal network connected to Internet via *router firewall*
- router *filters packet-by-packet*, decision to forward/drop packet based on:
 - source IP address, destination IP address
 - TCP/UDP source and destination port numbers
 - ICMP message type
 - TCP SYN and ACK bits

Packet filtering: more examples

<i>Policy</i>	<i>Firewall Setting</i>
No outside Web access.	Drop all outgoing packets to any IP address, port 80
No incoming TCP connections, except those for institution's public Web server only.	Drop all incoming TCP SYN packets to any IP except 130.207.244.203, port 80
Prevent Web-radios from eating up the available bandwidth.	Drop all incoming UDP packets - except DNS and router broadcasts.
Prevent your network from being used for a smurf DoS attack.	Drop all ICMP packets going to a "broadcast" address (e.g. 130.207.255.255).
Prevent your network from being tracerouted	Drop all outgoing ICMP TTL expired traffic

Intrusion detection systems

- packet filtering:
 - operates on TCP/IP headers only
 - no correlation check among sessions
- *IDS: intrusion detection system*
 - *deep packet inspection*: look at packet contents (e.g., check character strings in packet against database of known virus, attack strings)
 - examine correlation among multiple packets
 - port scanning
 - network mapping
 - DoS attack

firewall

Figuur 13

IDS



Intrusion detection systems

- multiple IDS's: different types of checking at different locations

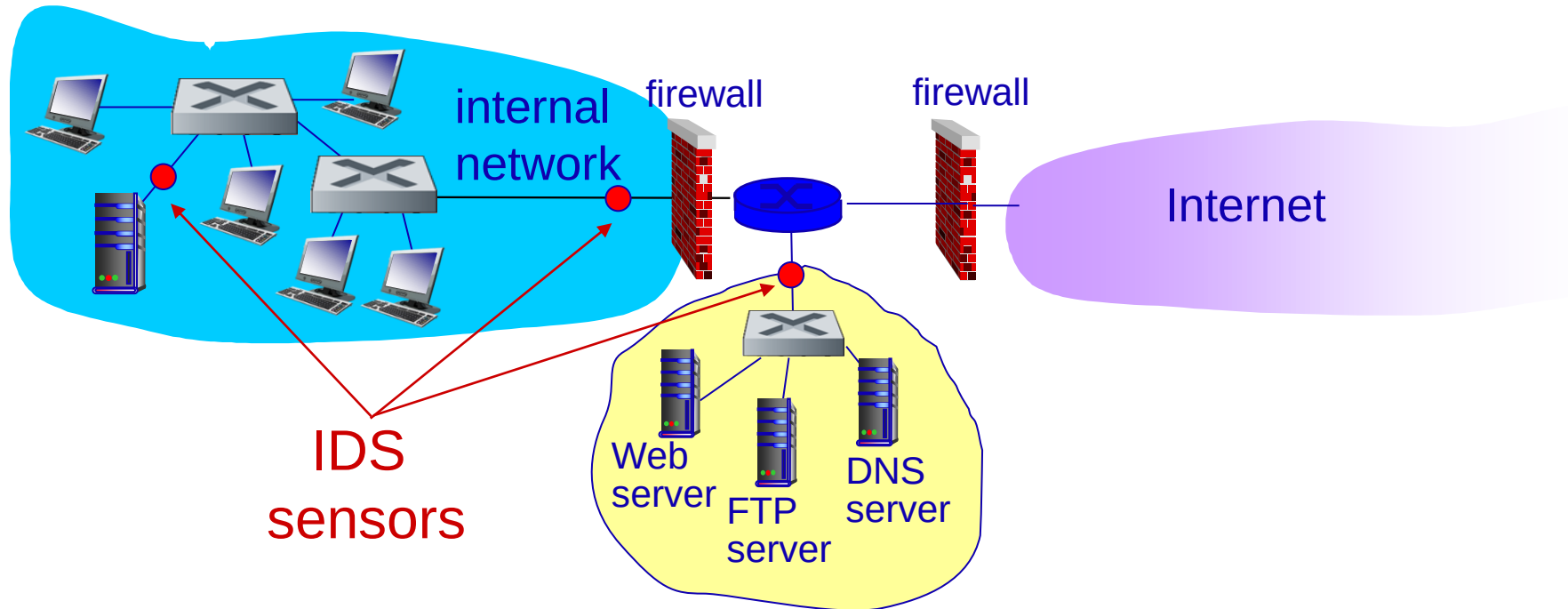


Figure 14

Demilitarized Zone (DMZ)

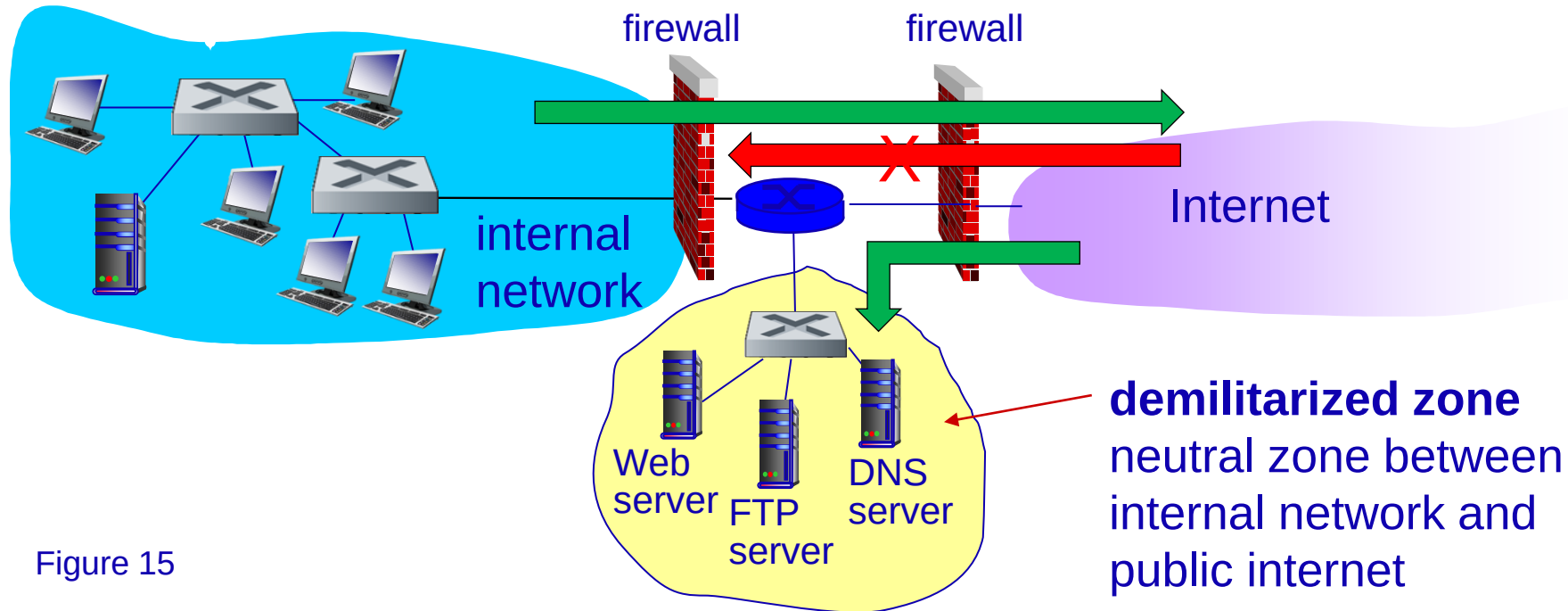


Figure 15

- Firewalls allow traffic from Internet to DMZ...
- and block traffic from Internet to internal network

Sources

- Figure 1,4,5,6,7,8,9,10,11,12,14,15,16: J.F. Kurose and K.W. Ross, Computer Networking, A Top-Down Approach, Pearson Education, 2013
- Figure 2: Elinor Mills, 20-7-2008, Mitnick fakes way into LA Telco Central Office - YouTube Video, CNET, retrieved on 9-3-2017 from <https://www.youtube.com/watch?v=8L76gTaReeg>
- Figure 3: Jay Paloma, 12-12-2007, Defense in Depth layers - Online afbeelding, retrieved on 10-3-2017 from <https://technet.microsoft.com/en-us/library/cc512681.aspx>
- Figure 13: Laura Porter, 15-8-2012, Exploring Windsor Castle - Online afbeelding, retrieved on 9-3-2017 from <http://www.anglotopia.net/site-news/featured/lauras-london-exploring-windsor-castle-the-queens-favorite-home-london-day-trip/>